

MICROSOFT DETECTION
AND RESPONSE TEAM (DART)

From one identity to full compromise

SPEAKERS

Sergio S. Matavos Galan
Victor Gonzalez
Lucas Mera



Meet the speakers



Victor
Gonzalez

**Senior Security Researcher · Microsoft
DART**

24+ years in IT, specializing in Azure, hybrid infrastructure, cybersecurity and recovery of critical operations across Latin America

Sergio S.
Matavos Galan

**Senior Security Researcher · Microsoft
DART**

12 years at Microsoft, focused on DFIR, threat hunting, identity security and cloud incident response across Microsoft 365, Azure and Defender XDR



MICROSOFT DART

It starts with an identity that does not look critical

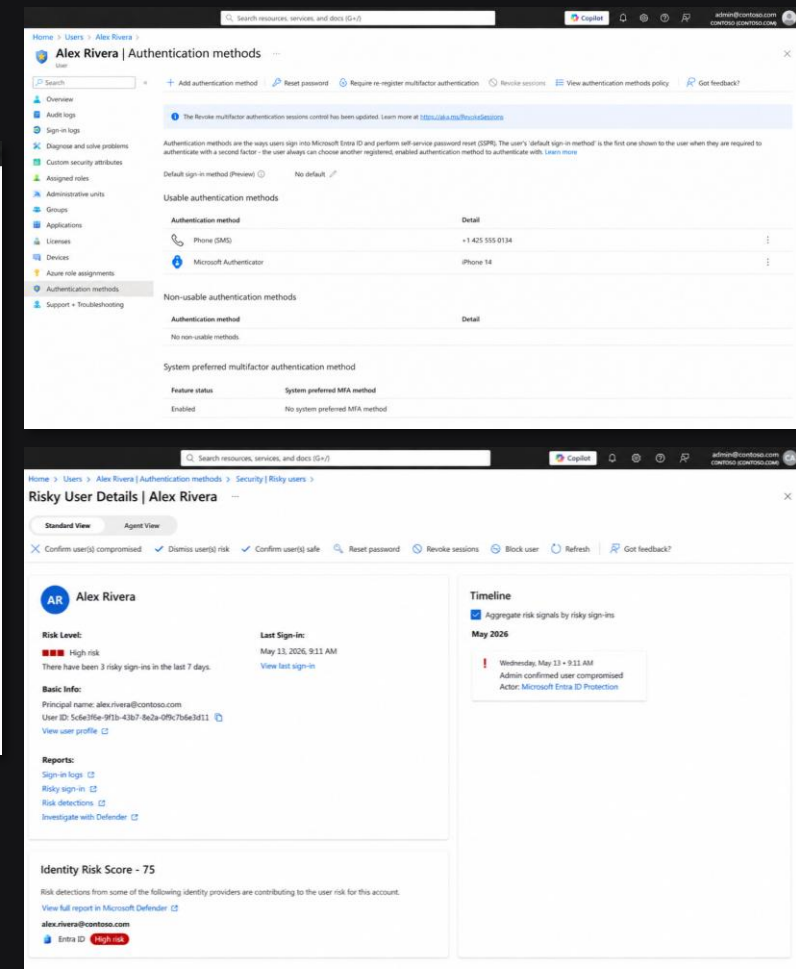
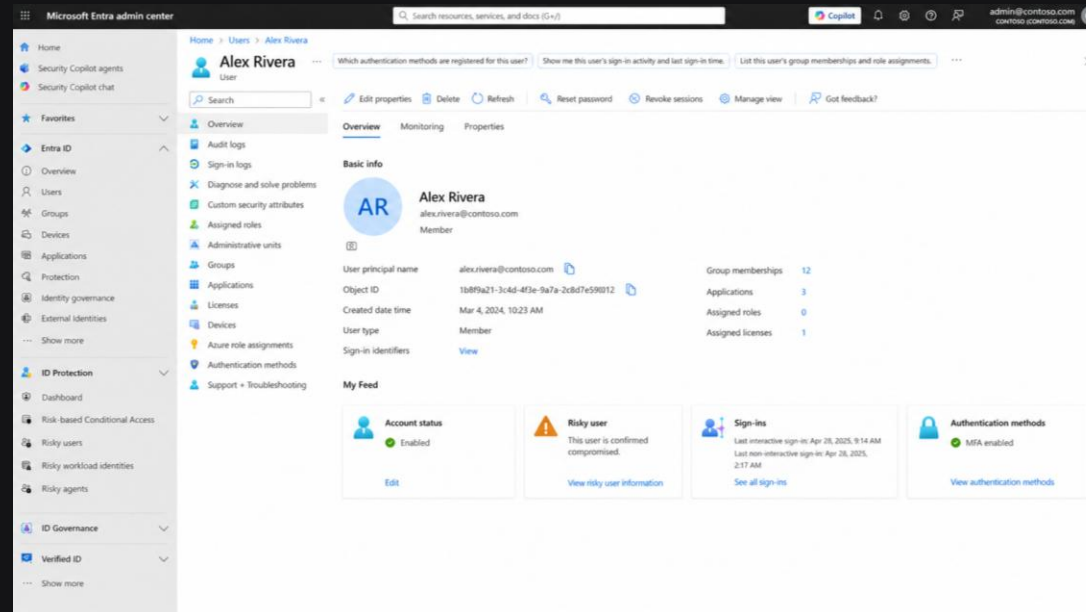
Case: Alex Rivera · valid identity, limited apparent privilege

Standard user

MFA enabled

No obvious admin role

Compromised



The investigation starts after the attacker already has Alex's valid identity.

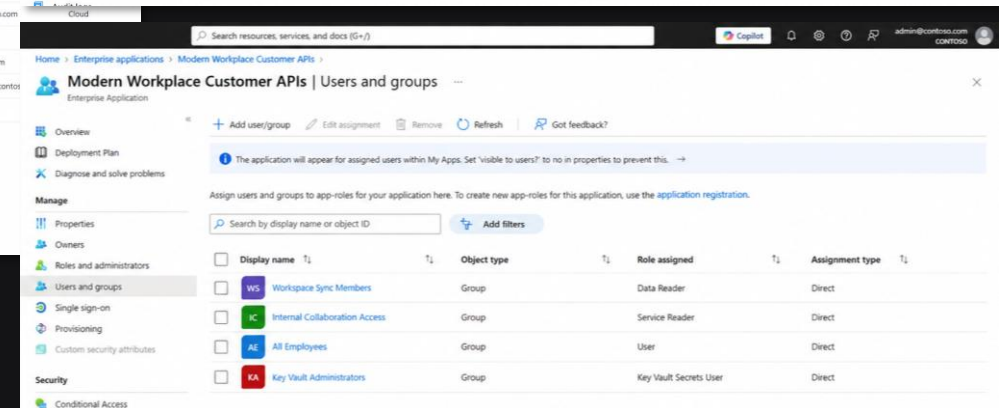
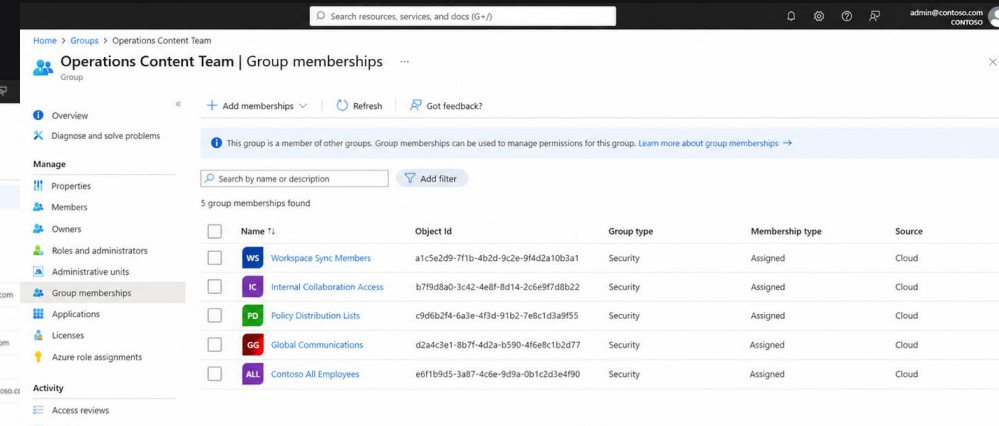
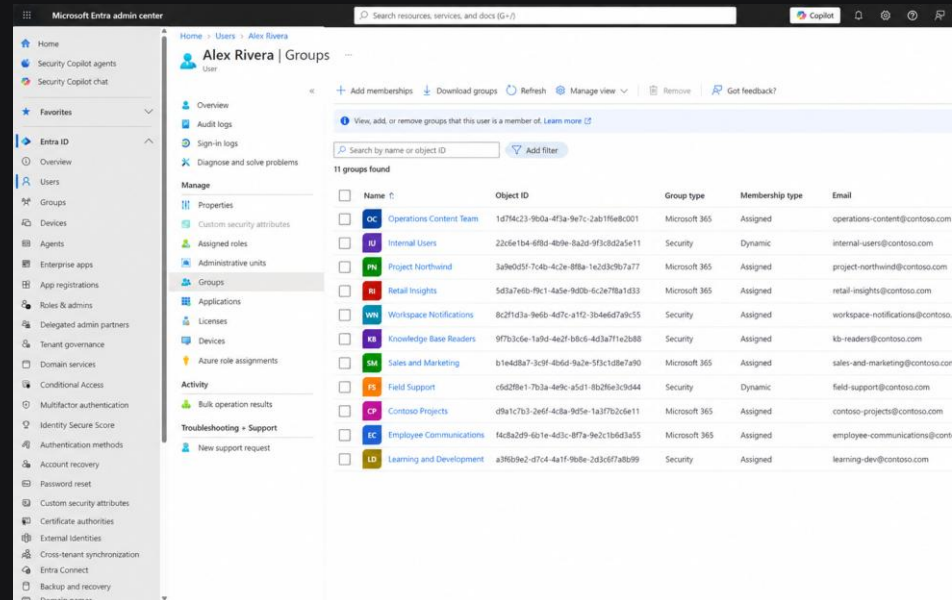
Direct permissions tell only part of the story

Case: Alex Rivera · direct assignments still look low risk

Direct view

User → Few visible roles

Looks low risk
when viewed in isolation

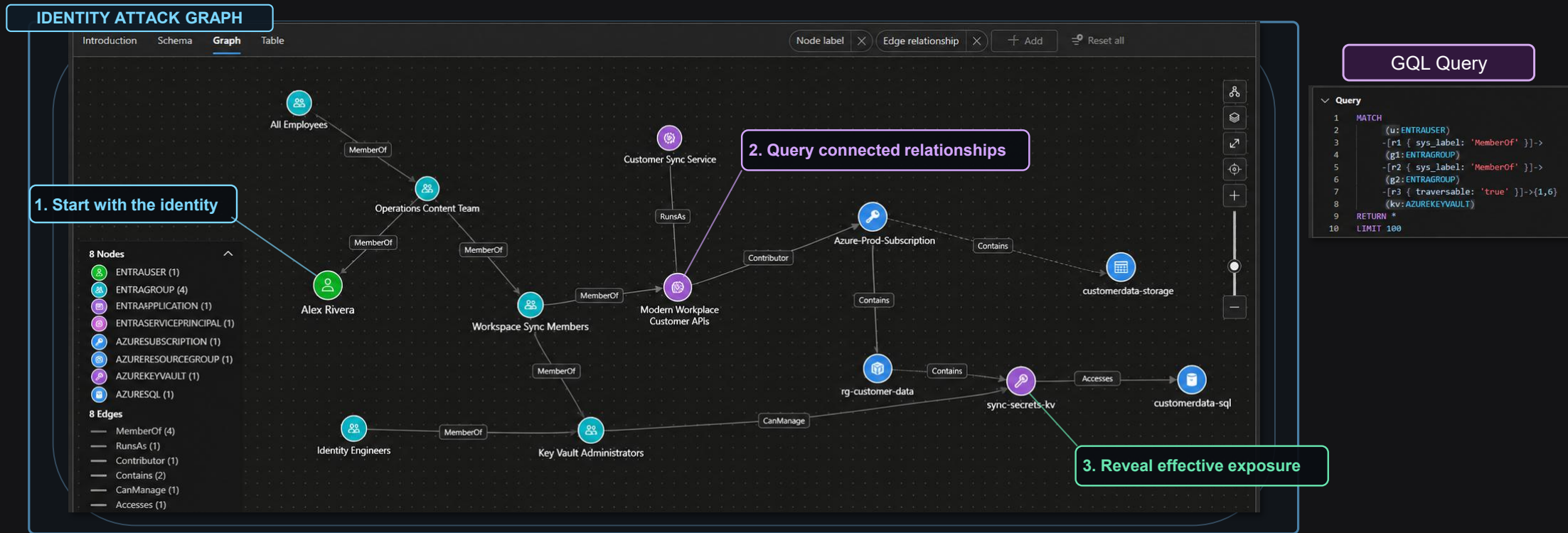


Direct access ≠ Effective access

The attack path we could not see

Identity Attack Graph reveals effective exposure across connected relationships

Case: Alex Rivera · direct assignments looked limited. Identity Attack Graph revealed what those relationships could reach.



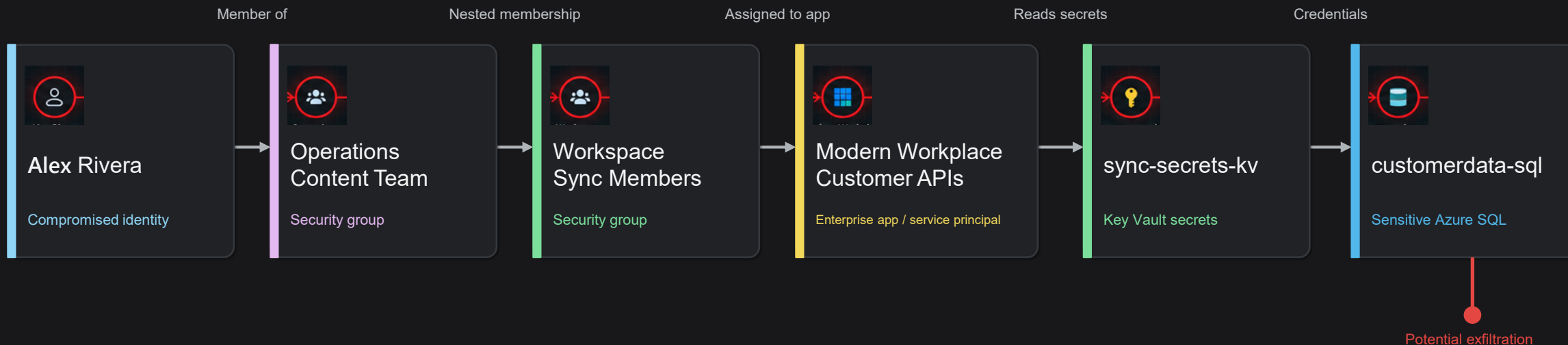
*Representative visualization based on validated relationships in the case

Direct access ≠ Effective exposure

Effective exposure emerges when identities, permissions and resource relationships are connected.

One relationship may be harmless. Combined, they are not

Case: Alex Rivera · exposure emerges from the chain



The risk is created by the chain, not by a single permission.

Nothing in isolation looked critical. The exposure appears only when the relationships are connected.

We have the signals. Now we need context.

Case: Alex Rivera · multiple signals now point to the same identity



Context turns signals into priorities.

AI can accelerate the investigation. It does not replace it

Entra ID Agent and AI capabilities

Case: Alex Rivera · use AI to prioritize, then validate the evidence

Review Alex Rivera's group memberships and identify whether any of those memberships could provide indirect access to applications or privileged resources. Explain which relationships deserve further investigation.

Copilot AI-generated content may be incorrect.

Prepared your response >

Based on the available Microsoft Entra data for Alex Rivera ([alex.rivera@contoso.com](#)), one relationship chain stands out as the highest-priority path for further investigation. Alex Rivera is a member of **Operations Content Team**, and this membership appears to continue through **Workspace Sync Members**, which is tied to the enterprise application **Modern Workplace Customer APIs**. That application is associated with a service principal and privileged permissions that can lead to Azure resources, including the Key Vault **sync-secrets-kv**. Access to secrets in that vault may expose credentials or connection details that could lead to **customerdata-sql** and sensitive customer data.

Alex Rivera's observed group memberships

1. **Operations Content Team** (Microsoft 365 group)
2. **Internal Users** (Security group)
3. **Project Northwind** (Microsoft 365 group)
4. **Retail Insights** (Microsoft 365 group)
5. **Workspace Notifications** (Security group)
6. **Knowledge Base Readers** (Security group)
7. **Sales and Marketing** (Microsoft 365 group)
8. **Field Support** (Security group)
9. **Contoso Projects** (Microsoft 365 group)
10. **Employee Communications** (Microsoft 365 group)
11. **Learning and Development** (Security group)

Analysis & indirect access risks

- **High-priority relationship path:** Alex Rivera → **Operations Content Team** → **Workspace Sync Members** → **Modern Workplace Customer APIs** → **sync-secrets-kv** → **customerdata-sql**.
- **Operations Content Team:** This is the visible starting membership for Alex Rivera and should be validated for effective access and nested relationships.
- **Workspace Sync Members:** This group is the key security group in the chain and may grant access to the enterprise application. Its membership and role in the chain should be reviewed.
- **Modern Workplace Customer APIs:** This enterprise application should be reviewed for assignment to Workspace Sync Members and for the service principal permissions granted to it.
- **sync-secrets-kv:** This Key Vault should be reviewed to determine whether secret read access could expose credentials, tokens, or connection strings.
- **customerdata-sql:** This appears to be a sensitive Azure SQL resource that may be indirectly exposed through the chain.
- **Other visible memberships:** The remaining group memberships (Internal Users, Project Northwind, Retail Insights, Workspace Notifications, Knowledge Base Readers, Sales and Marketing, Field Support, Contoso Projects, Employee Communications, and Learning and Development) do not show a direct path to sensitive resources based on the available data, but they could introduce additional access depending on application assignments or privileged roles and are lower priority.

Relationships deserving further investigation

1. **Alex Rivera → Operations Content Team**
 - Validate Alex Rivera's effective access to this group and review its nested group relationships.
2. **Operations Content Team → Workspace Sync Members**
 - Review whether Operations Content Team is nested in or otherwise associated with Workspace Sync Members.
3. **Workspace Sync Members → Modern Workplace Customer APIs**
 - Confirm that Workspace Sync Members is assigned to this enterprise application.
4. **Modern Workplace Customer APIs → sync-secrets-kv**
 - Review the service principal permissions for this application, including access to the Key Vault **sync-secrets-kv**.
5. **sync-secrets-kv → customerdata-sql**
 - Determine whether access to secrets in this Key Vault could lead to access to **customerdata-sql** or other sensitive resources.

This path deserves priority because the exposure emerges from the connected relationships rather than from a single direct role.

Show nested group relationships for Operations Content Team.

List enterprise application assignments linked to Workspace Sync Members.

Show service principal permissions for Modern Workplace Customer APIs.

Ask a question, search for info, or get help with a task in Security...

AI-generated content may be incorrect. Check it for accuracy.

What should we validate?

Ask the right question

Evidence behind the answer

Analyst validation

Decision ownership

UNDERSTAND

Want to know more: [AI for Security in Microsoft Entra](#)

AI prioritized the path. Now we validate it.

From AI-guided investigation to analyst-validated evidence

Case: Alex Rivera · follow the evidence beyond identity

ANALYST VALIDATES

AI PRIORITIZES

Review Alex Rivera's group memberships and identify whether any of those memberships could provide indirect access to applications or privileged resources. Explain which relationships deserve further investigation.

Copilot AI-generated content may be incorrect.

Prepared your response >

Based on the available Microsoft Entra data for Alex Rivera (alex.rivera@contoso.com), one relationship chain stands out as the highest-priority path for further investigation. Alex Rivera is a member of **Operations Content Team**, and this membership appears to continue through **Workspace Sync Members**, which is tied to the enterprise application **Modern Workplace Customer APIs**. That application is associated with a service principal and privileged permissions that can lead to Azure resources, including the Key Vault **sync-secrets-kv**. Access to secrets in that vault may expose credentials or connection details that could lead to **customerdata-sql** and sensitive customer data.

Alex Rivera's observed group memberships

1. **Operations Content Team** (Microsoft 365 group)
2. **Internal Users** (Security group)
3. **Project Northwind** (Microsoft 365 group)
4. **Retail Insights** (Microsoft 365 group)
5. **Workspace Notifications** (Security group)
6. **Knowledge Base Readers** (Security group)
7. **Sales and Marketing** (Microsoft 365 group)
8. **Field Support** (Security group)
9. **Contoso Projects** (Microsoft 365 group)
10. **Employee Communications** (Microsoft 365 group)
11. **Learning and Development** (Security group)

Analysis & Indirect access risks

- **High-priority relationship path:** Alex Rivera → **Operations Content Team** → **Workspace Sync Members** → **Modern Workplace Customer APIs** → **sync-secrets-kv** → **customerdata-sql**
- **Operations Content Team:** This is the visible starting membership for Alex Rivera and should be validated for effective access and nested relationships.
- **Workspace Sync Members:** This group is the key security group in the chain and may grant access to the enterprise application. Its membership and role in the chain should be reviewed.
- **Modern Workplace Customer APIs:** This enterprise application should be reviewed for assignment to Workspace Sync Members and for the service principal permissions granted to it.
- **sync-secrets-kv:** This Key Vault should be reviewed to determine whether secret read access could expose credentials, tokens, or connection strings.
- **customerdata-sql:** This appears to be a sensitive Azure SQL resource that may be indirectly exposed through the chain.
- **Other visible memberships:** The remaining group memberships (Internal Users, Project Northwind, Retail Insights, Workspace Notifications, Knowledge Base Readers, Sales and Marketing, Field Support, Contoso Projects, Employee Communications, and Learning and Development) do not show a direct path to sensitive resources based on the available data, but they could introduce additional access depending on application assignments or privileged roles and are lower priority.

Relationships deserving further investigation

1. **Alex Rivera** → **Operations Content Team**
 - Validate Alex Rivera's effective access to this group and review its nested group relationships.
2. **Operations Content Team** → **Workspace Sync Members**
 - Review whether Operations Content Team is nested in or otherwise associated with Workspace Sync Members.
3. **Workspace Sync Members** → **Modern Workplace Customer APIs**
 - Confirm that Workspace Sync Members is assigned to this enterprise application.
4. **Modern Workplace Customer APIs** → **sync-secrets-kv**
 - Review the service principal permissions for this application, including access to the Key Vault **sync-secrets-kv**.
5. **sync-secrets-kv** → **customerdata-sql**
 - Determine whether access to secrets in this Key Vault could lead to access to **customerdata-sql** or other sensitive resources.

This path deserves priority because the exposure emerges from the connected relationships rather than from a single direct role.

Show nested group relationships for Operations Content Team.

List enterprise application assignments linked to Workspace Sync Members.

Show service principal permissions for Modern Workplace Customer APIs.

Ask a question, search for info, or get help with a task in Security.

AI-generated content may be incorrect. Check it for accuracy.

VALIDATE

Follow the evidence

1

RESOURCE PATH

Azure-Prod-Subscription | Resources

Name	Type	Resource Group	Location	Subscription
sync-secrets-kv	Key vault	rg-shared-security	East US	Azure-Prod-Subscription
customerdata-sql	Azure SQL database	rg-data	East US	Azure-Prod-Subscription
app-prod-web	App Service	rg-apps	East US	Azure-Prod-Subscription
prod-vnet	Virtual network	rg-network	East US	Azure-Prod-Subscription
log-analytics-prod	Log Analytics workspace	rg-monitoring	East US	Azure-Prod-Subscription
storage-prod	Storage account	rg-shared	East US	Azure-Prod-Subscription
aks-prod	Kubernetes service	rg-apps	East US	Azure-Prod-Subscription
appgw-prod	Application gateway	rg-network	East US	Azure-Prod-Subscription
ku-managed-identity	User-assigned managed identity	rg-shared-security	East US	Azure-Prod-Subscription
apigateway-prod	Application Insights	rg-monitoring	East US	Azure-Prod-Subscription
vpn-private-endpoint	Private endpoint	rg-network	East US	Azure-Prod-Subscription
backup-vault	Recovery Services vault	rg-shared	East US	Azure-Prod-Subscription

3

CREDENTIAL

sync-secrets-kv | Secrets

customerdata-sql-admin-password

Secret identifier: https://sync-secrets-kv.vault.azure.net/secrets/customerdata-sql-admin-password/f2c9d8a7-4b1e-4e6d-9c3a-2b7f5e8d9c01

Secret value: [REDACTED]

2

SENSITIVE VAULT

sync-secrets-kv | Secrets

Name	Type	Status	Expiration date	Last updated
customerdata-sql-admin-password	Generic	Enabled	-	Apr 25, 2024, 2:18 PM
customerdata-sql-admin-user	Generic	Enabled	-	Apr 25, 2024, 2:17 PM
customerdata-sql-admin-password	Generic	Enabled	-	Apr 25, 2024, 2:17 PM
storage-report-sql	Generic	Enabled	-	Apr 24, 2024, 11:03 AM
resource-website-key	Generic	Enabled	-	Apr 22, 2024, 9:41 AM

4

DATA EXPOSURE

customerdata-sql | Query editor

Query 1: SELECT TOP 20 CustomerId, FullName, Email, Country, AccountBalance FROM dbo.Customers;

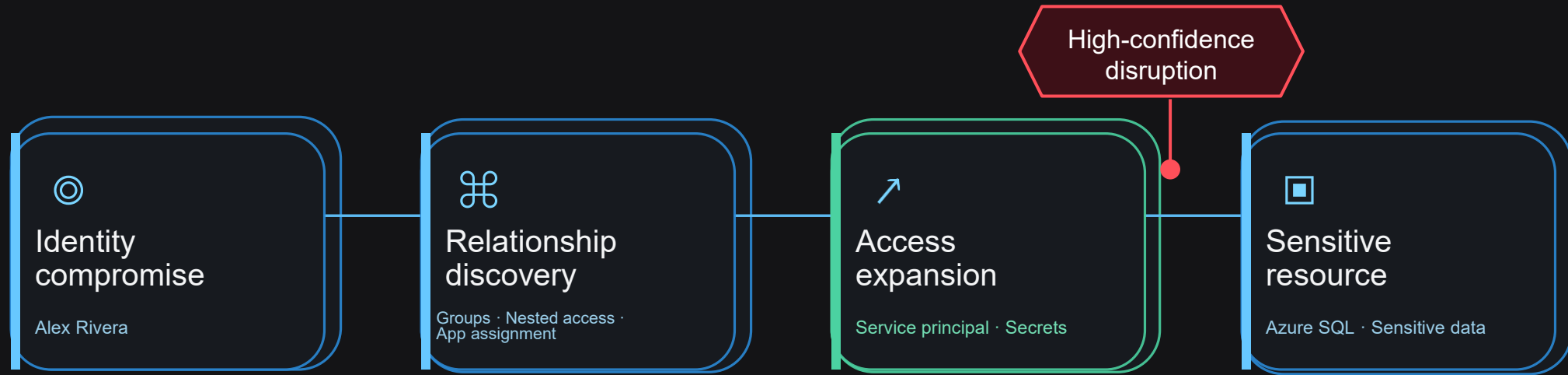
CustomerId	FullName	Email	Country	AccountBalance
1001	Samir Johnson	samir.johnson@contoso.com	United States	12,490.50
1002	Michael Chen	michael.chen@contoso.com	United States	8,910.25
1003	Emma Wilson	emma.wilson@contoso.com	United Kingdom	25,150.00
1004	David Garcia	david.garcia@contoso.com	Canada	3,240.75
1005	Prag Sharma	prag.sharma@contoso.com	India	10,800.10
1006	James Miller	james.miller@contoso.com	United States	6,780.00
1007	Sophia Brown	sophia.brown@contoso.com	Australia	14,320.40
1008	David Rodriguez	david.rodriguez@contoso.com	Spain	9,030.00
1009	Olivia Taylor	olivia.taylor@contoso.com	United States	11,214.90
1010	William Anderson	william.anderson@contoso.com	Canada	7,890.80
1011	Sofia Brown	sofia.brown@contoso.com	Germany	16,450.00
1012	Ethan Moore	ethan.moore@contoso.com	United States	12,490.50
1013	Mia Jackson	mia.jackson@contoso.com	France	13,475.80
1014	Alexander White	alexander.white@contoso.com	United Kingdom	10,990.00
1015	Charlotte Harris	charlotte.harris@contoso.com	Australia	8,220.00
1016	Bernardo Martin	bernardo.martin@contoso.com	United States	5,430.75
1017	Anika Thompson	anika.thompson@contoso.com	Canada	21,340.00
1018	Lucas Lee	lucas.lee@contoso.com	Singapore	6,780.40
1019	Nayan Clark	nayan.clark@contoso.com	United States	8,910.25
1020	Eliot Rodriguez	eliot.rodriguez@contoso.com	Mexico	12,110.20

UNDERSTAND

Want to know more: [AI for Security in Microsoft Entra](#)

When do we stop investigating and start acting?

Case: Alex Rivera · the investigation now has enough context to consider action



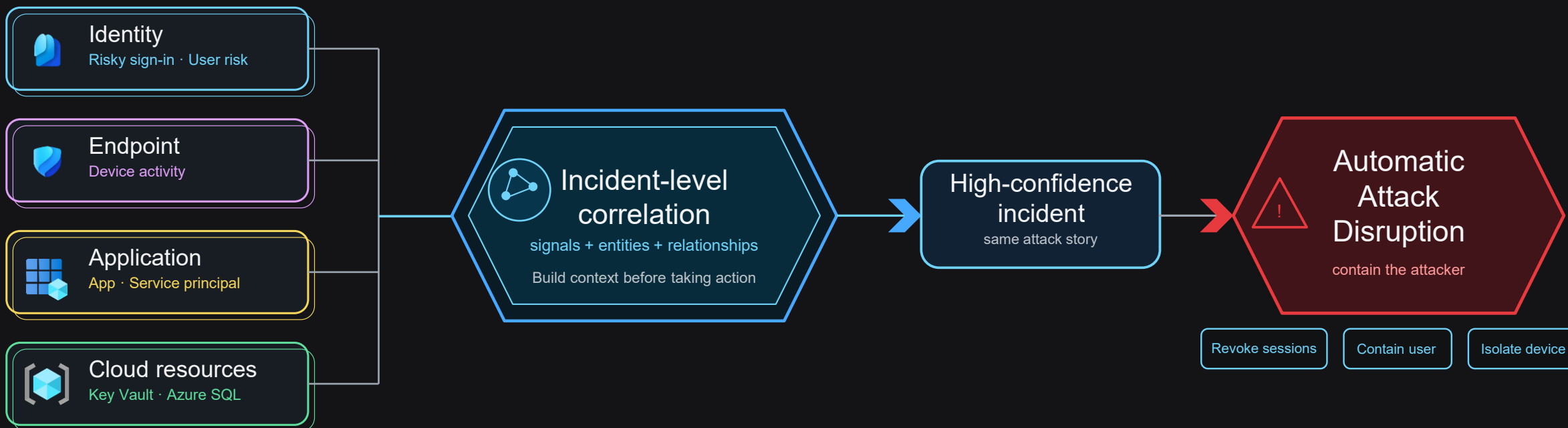
Defender acts when correlated signals establish **high confidence** that an attack is in progress.

Automatic Attack Disruption is not magic. It is correlation

Automatic Attack Disruption in Microsoft Defender

Case: Alex Rivera · multiple signals converge into one high-confidence incident

SECURITY SIGNALS

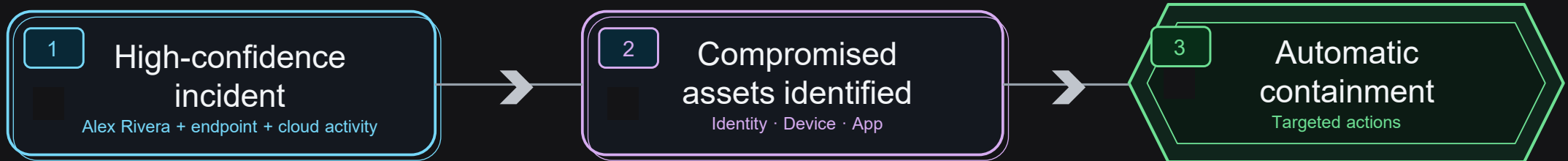


One signal may not justify disruption. **Correlated signals can.**

What does Attack Disruption actually stop?

Incident-level containment designed to limit attacker movement while responders remediate

Case: Alex Rivera · containment targets attacker-controlled identity and related assets



Containment actions

Revoke sessions

Cuts active attacker sessions

Contain user

Limits use of the compromised identity

Isolate device

Blocks the attacker foothold

Contain app

Restricts compromised application access

What does this stop?

Session reuse

Attacker cannot keep replaying active sessions

Lateral movement

Slows spread across related identities and assets

Continued access

Reduces ongoing use of compromised resources

Progress to sensitive resources

Helps interrupt movement toward key data

Disruption buys response time. It does not replace remediation.

What does Attack Disruption look like in practice?

Automatic Attack Disruption in Microsoft Defender

Case: Alex Rivera · correlated evidence triggers and records automatic response



Multiple identity, endpoint, app and cloud signals converge into one high-confidence incident.

The Activity view provides an auditable record of what Attack Disruption actually did.

Incidents > User account compromise identified from a known attack pattern (attack disruption)

ID 57083: User account compromise identified from a known attack pattern (attack disruption)

High | Active | Defender Experts | True alert | Last updated: Aug 27, 2024 3:18 PM | Critical asset | Credential phishing | Attack disruption | Initial access | +2

Automated response actions were completed for this incident.

Attack story | Alerts (8) | **Activities (28)** | Assets (10) | Investigations (3) | Evidence and response (14) | Recommended actions (6) | Summary | Similar incidents (2)

Other incidents were combined into this incident. The table shows the activities from the combined incidents.

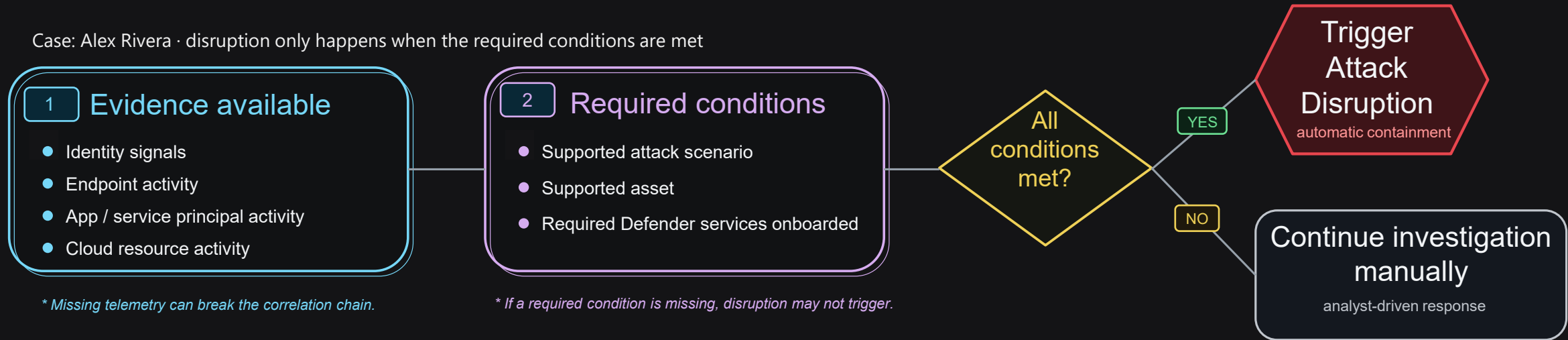
Refresh | Export | 3 items | Last 6 months | Search | Customize columns

Filters: Source: This incident | Performed by: Attack disruption | + Add filter | Reset all

☐	Start time	Title	Type	Category	Target	Performed by	Triggered by	Triggering alert	Action status
☐	Aug 27, 2024 8:14 AM	Alex Rivera confirmed compromised	Confirm user account compromise	Response	Alex Rivera	Attack disruption	Automated	Compromised user account identified from a known attack pattern	Completed
☐	Aug 27, 2024 8:14 AM	Alex Rivera contained	Contain user	Response	Alex Rivera	Attack disruption	Automated	Compromised user account identified from a known attack pattern	Completed
☐	Aug 27, 2024 8:14 AM	Alex Rivera required to sign in again	Revoke active sessions	Response	Alex Rivera	Attack disruption	Automated	Compromised user account identified from a known attack pattern	Completed

What if Attack Disruption does not trigger?

Case: Alex Rivera · disruption only happens when the required conditions are met



Alex Rivera example

Identity risk + endpoint activity + cloud activity may be present, but if a required condition or supported scenario is missing, Defender may not trigger automatic disruption.

No disruption does not mean no compromise. It means the conditions for automatic containment were not met.

Attack disrupted. Are we recovered?

Case: Alex Rivera · contained does not mean restored



Containment stops the attacker. Recovery restores trusted state.

What may already have changed?

AUTH

Alex Rivera | Authentication methods

Search: [] + Add authentication method Reset password Require re-register multifactor authentication Revoke sessions View authentication methods policy Got feedback?

The Revoke multifactor authentication sessions control has been updated. Learn more at <https://aka.ms/RevokeSessions>

Authentication methods are the ways users sign into Microsoft Entra ID and perform self-service password reset (SSPR). The user's default sign-in method is the first one shown to the user when they are required to authenticate with a second factor - the user always can choose another registered, enabled authentication method to authenticate with. [Learn more](#)

Default sign-in method (Preview) No default

Usable authentication methods

Authentication method	Detail
Phone (SMS)	+1 425 555 0104
Microsoft Authenticator	iPhone 14
Phone (SMS)	+7 916 123 4567 New

GROUP

Operations Content Team | Members

Home > Groups > Operations Content Team

Overview Diagnose and solve problems

Manage

Properties

Members

6 members found

Name	User principal name	User type	Source
☐ Alex Rivera	alex.rivera@contoso.com	Member	Cloud
☐ Megan Collins	megan.collins@contoso.com	Member	Cloud
☐ Priya Shah	priya.shah@contoso.com	Member	Cloud
☐ Diego Alvarez	diego.alvarez@contoso.com	Member	Cloud
☐ Workspace Sync Members	a1c5e3b9-711b-4b2d-9c2e-9f4d3a1081a1	Member	Cloud
☐ Not A Hacker At All	not.a.hacker.at.all_attacker.com#EXT#@contoso.onmicrosoft.com	Guest New	External Azure AD

Restore trust, not just configuration

Microsoft Entra Backup and Recovery

Case: Alex Rivera · recover a known-good identity state

1 Known-good

Expected auth
Expected groups
Expected identity access

2 Compromised

Malicious auth added
Guest introduced
Identity state drift

3 Recovered

Malicious changes removed
Expected access restored
State validated

Restore affected identity objects

Compare

Alex Rivera

+7 phone added

Guest in group

Trust state changed

Restore

Selected for recovery

Remove malicious auth

Remove guest member

Restore expected group state

Validate

Post-restore checks

Expected auth methods only

Group membership trusted

Identity state trusted

Targeted object recovery, not a rollback of the entire tenant

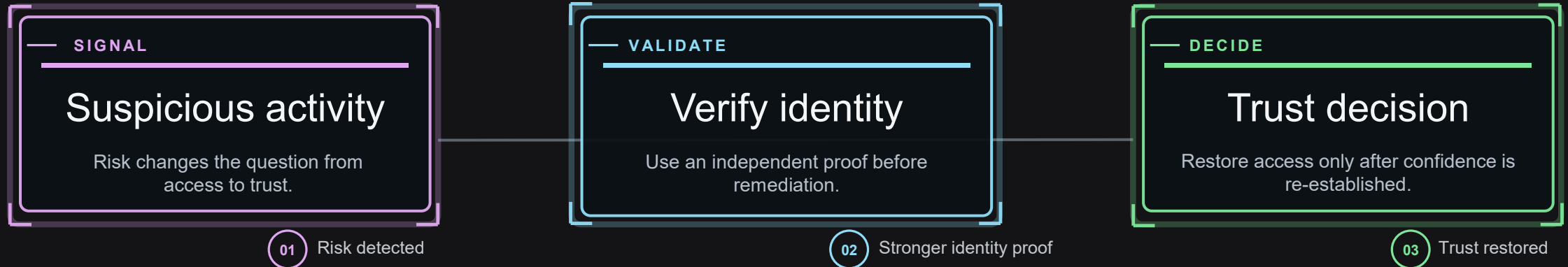
The screenshot displays the Microsoft Entra admin center interface. The main pane shows the 'Backup and recovery | Backups' section with a table of backup operations. The 'Recover backup' pane is open on the right, showing the 'Select objects' step. The 'Selected backup' section indicates the backup time is February 20, 2026 at 5:00:00 AM (UTC) and the backup ID is 9a7e6c11-6d3b-4f84-9c2a-0e7f1c6a4932. The 'Choose what to include in the recovery' section has 'Restore only specific identity objects (recommended)' selected. The 'Select object type' dropdown is set to 'User'. The 'Select users' section shows 'Alex Rivera' selected. The 'Next steps' section shows a flow: Compare current state → Restore affected identity objects → Validate trusted state.

Backup timestamp	Backup ID	Status
2/23/2026, 5:00:00 AM	b12f0d9e-3a8d-4c2b-9f0e-...	Completed
2/20/2026, 5:00:00 AM	9a7e6c11-6d3b-4f84-9c2a-...	Completed
2/16/2026, 5:00:00 AM	4f3c2b81-0d7e-4651-8a6c-...	Completed
2/13/2026, 5:00:00 AM	8c9d7a12-5e1f-4b30-90d5-...	Completed
2/9/2026, 5:00:00 AM	c0a4e7f9-1b2c-47d6-a8f3-...	Completed

Authentication is not always enough to establish trust

Microsoft Entra Verified ID

Case: Alex Rivera · verify the person before restoring trust



Create credential: Verified employee

Card styling

Customize the design of your verifiable credential. [Learn more](#)

Logo URL *

Text color *

Background color *

Verification method

Credential: Contoso Employee Credential

Verified ID

Verification result

Credential verified

The presented credential is valid and issued by Contoso HR.

Issuer status: Trusted issuer

Credential status: Valid

Identity match: Matches Alex Rivera

Verified on: Mar 3, 2025, 10:26 AM (UTC)

Directory & claims

Your directory was used to generate verified claims.

Directory	Claims	Directory attributes
Caldova	displayName	displayName
	givenName	givenName
	jobTitle	jobTitle
	preferredLanguage	preferredLanguage
	surname	surname
	mail	mail
	revocationid	userPrincipalName
	photo	photo

**Illustrative verification example*

What else could we recover?

Microsoft Entra Backup and Recovery

Case extension: Alex Rivera · restoring a compromised application to a known-good state

1 Known-good

Approved permissions
Expected API access
Trusted application state

2 Compromised

New permission granted
Storage.Blob.Read.All added
Application state changed

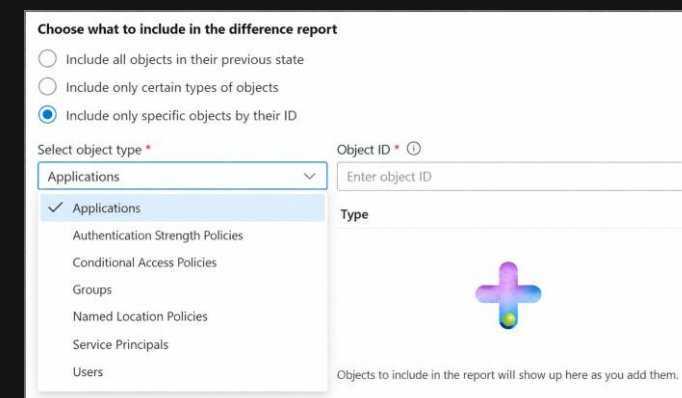
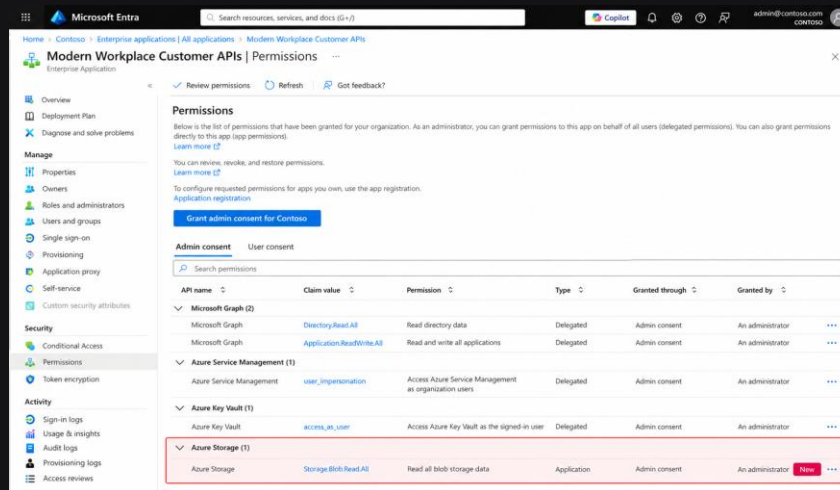
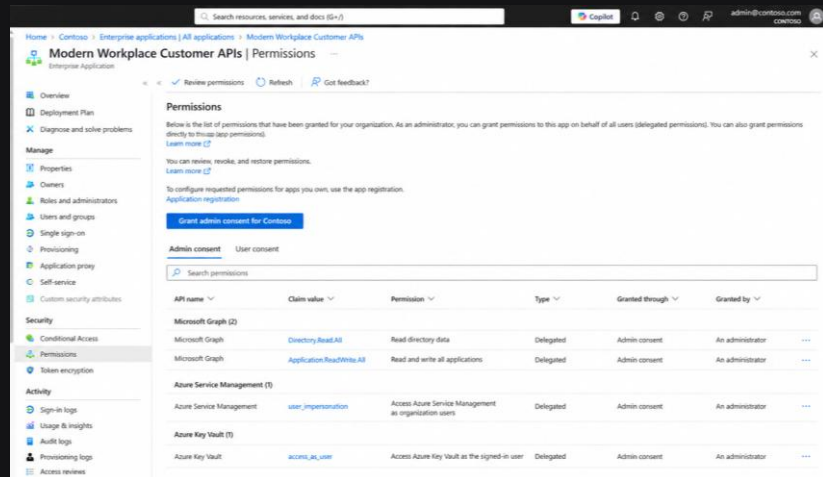
3 Recovered

Unauthorized permission removed
Approved permissions restored
Application state validated

BASELINE

DRIFT DETECTED

SELECT FOR RECOVERY

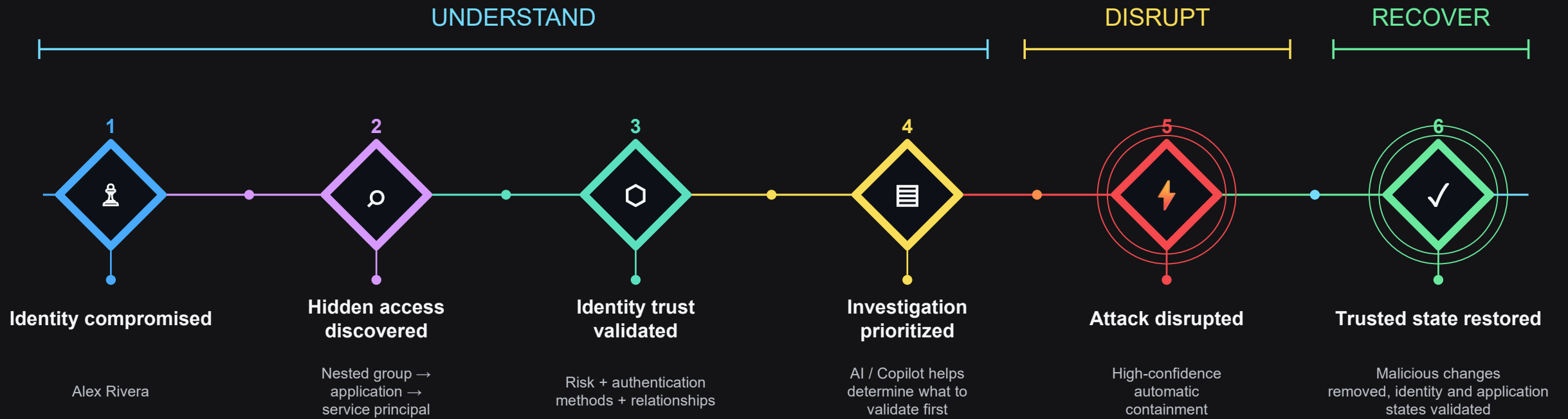


RECOVER

Want to know more: [Microsoft Entra Backup and Recovery](#)

From one identity to the entire incident

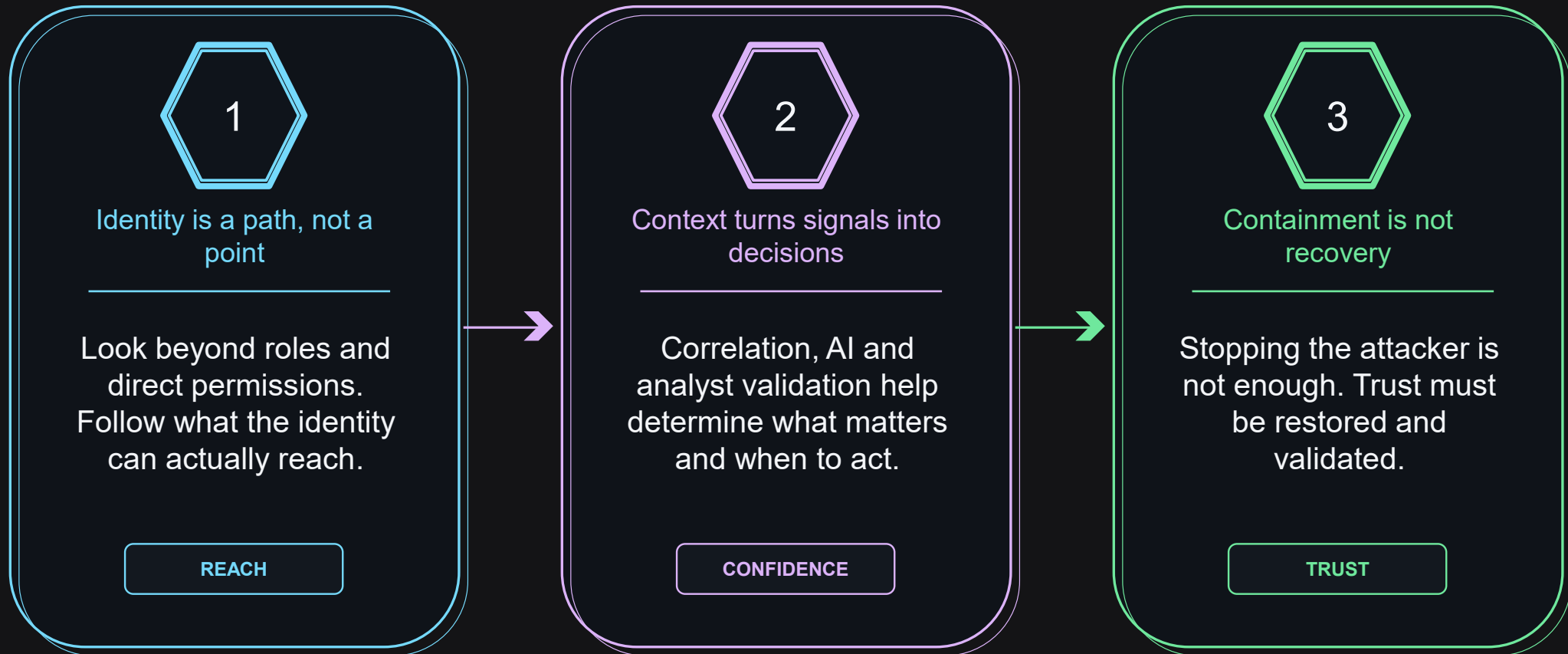
Case: Alex Rivera · one incident from compromise to trusted recovery



One incident. Different decision points. One identity-driven story.

Three things to take away

The story in three decisions



Follow the path. Build the context. Restore the trust.

Questions

QR

Thanks for your time.

Lucas Mera · Victor Gonzalez · Sergio S. Matavos Galan

